



Dr. Ammar Haider
Assistant Professor
School of Computing

CS3002 Information Security

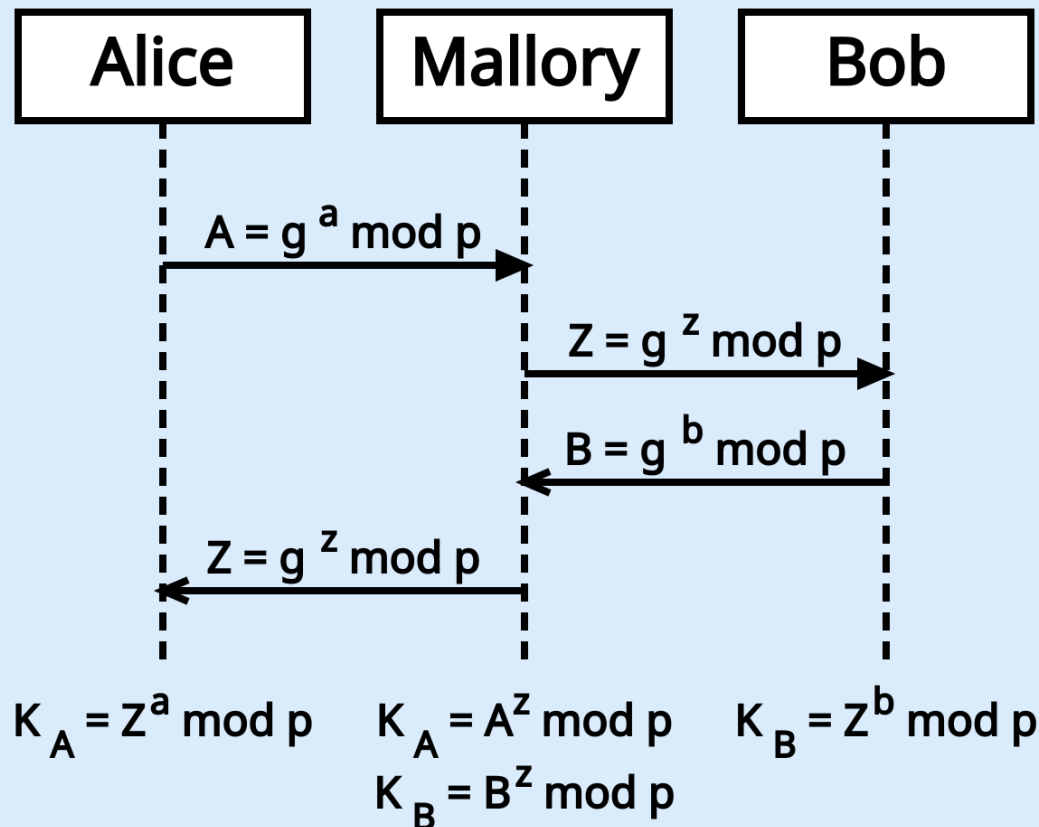


Public Key Infrastructure

MITM against Diffie-Hellman



- Recap: Diffie-Hellman key exchange is vulnerable to man in the middle attack



MITM in PKC



- MITM is not unique to Diffie–Hellman key exchange
- All kinds of asymmetric crypto (RSA, digital signatures, digital envelope etc.) is vulnerable to such attacks
- Whenever public keys are exchanged over an insecure channel, we can not blindly trust the received public key.

Public-Key Certificates

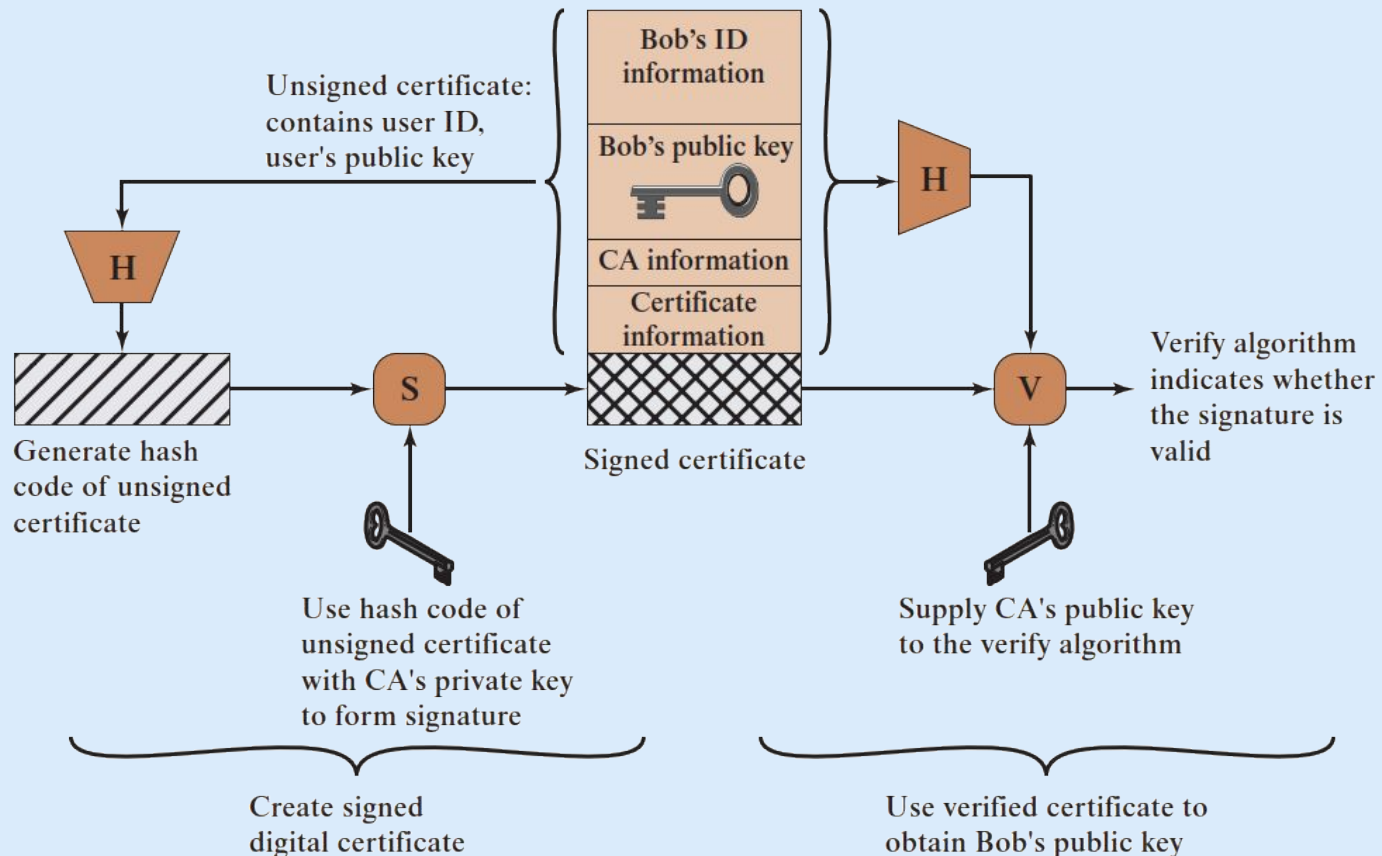


- To prevent MITM against PKC, digital certificates are used.
- A certificate associates a public key with an individual/company
- Digital certificate is just a piece of data
 - A public key and ID of key owner, whole block signed by a **trusted third party**
- Issued by a Certificate Authority (CA)
- Helps in authentication

Public-Key Certificate



- Signing a certificate by CA



Public-Key Certificate

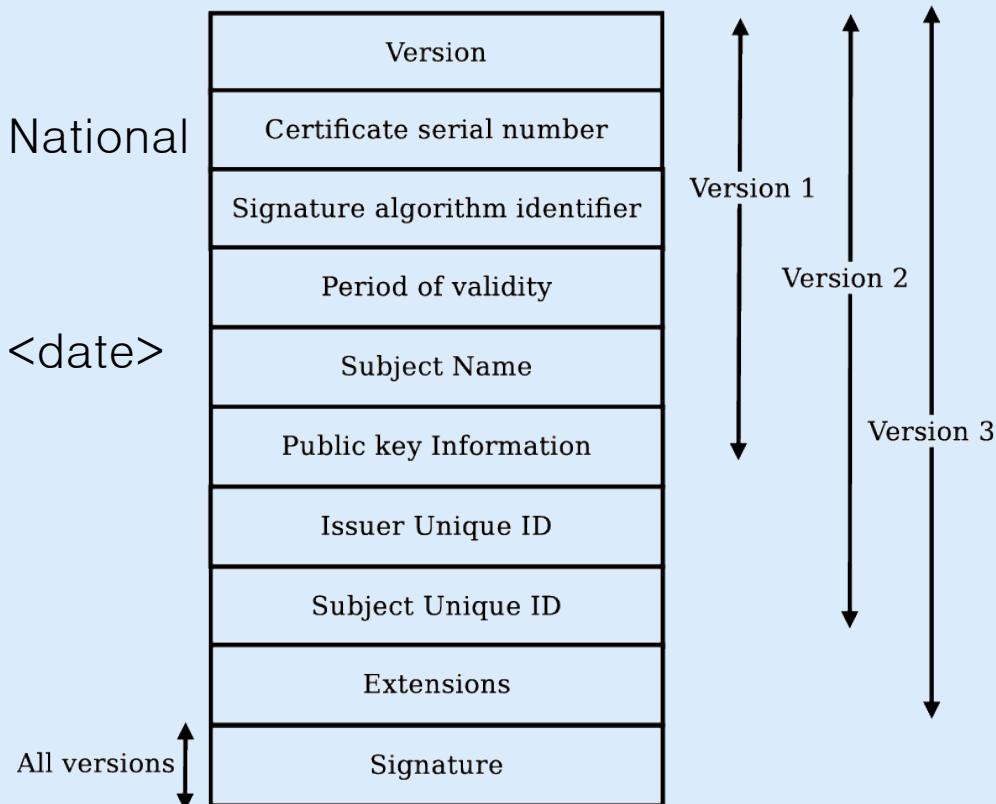


- Contains the following information:
 - who issued the certificate: Comodo, Symantec etc.
 - who the certificate is issued to (aka subject)
 - public key of the owner
 - validity period
 - digital signature by CA
- X.509: International Standard for the format of a public-key certificate

X.509 Identity Certificates



- Distinguished Name of user
 - C=US, O=Lawrence Berkeley National Laboratory, OU=DSD, CN=Mary R. Thompson
- DN of Issuer
 - C=US, O=Lawrence Berkeley National Laboratory, CN=LBNL-CA
- Validity dates:
 - Not before <date>, Not after <date>
- User's public key
- V3 extensions
- CA signatures
- Defined in **ASN.1 notation**
 - language independent



Public Key Infrastructure (PKI)



- PKI is the set of hardware, software, and procedures needed to create, store, distribute and revoke digital certificates

Elements of PKI

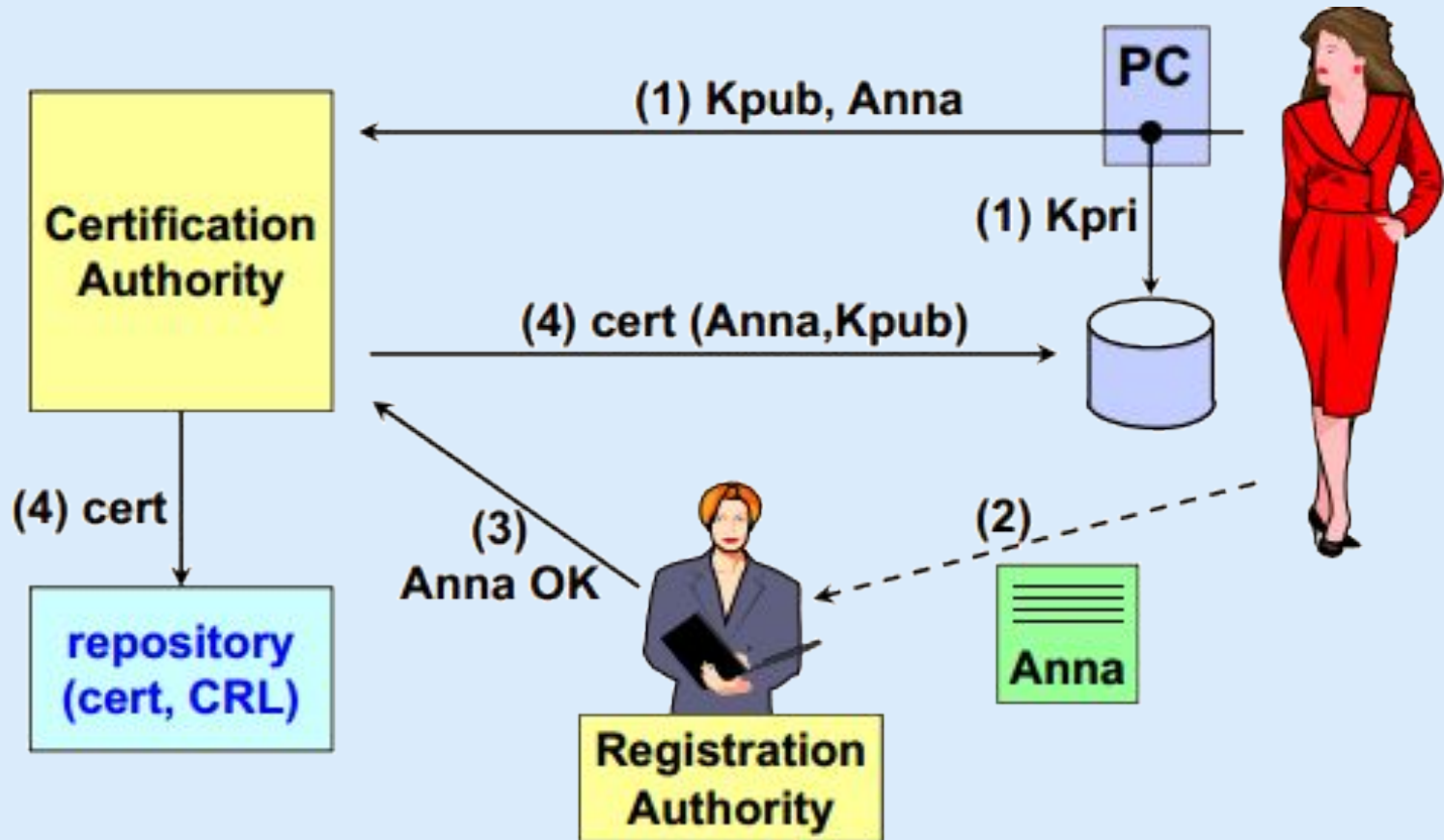
- X.509 Certificates
- Certificate Authorities (CA)
- Registration Authorities (RA)
- Public/Private Key Pairs
- Certificate Revocation Lists

Certificate Authority



- A third party. Must be a secure server
 - Signs and publishes X.509 Identity certificates
 - Revokes certificates and publishes a Certification Revocation List (CRL)
- Anyone can sign certificates (act as CA), but their certificates will have no value unless the users **trust** them.
- Trusting means the certificate inspector (receiver) already knows about this CA, and has pre-saved the CA's public key in its records.
 - so that they can verify CA's signatures

Certificate Issuance Process



Registration Authority



- An RA is responsible for accepting requests for digital certificates and authenticating the entity making the request.
- You provide RA with information and fees
- RA verifies the information before the CA issues the certificate
- RA does not sign the certificate
- Your key pair maybe created by RA or yourself

Trusted CAs

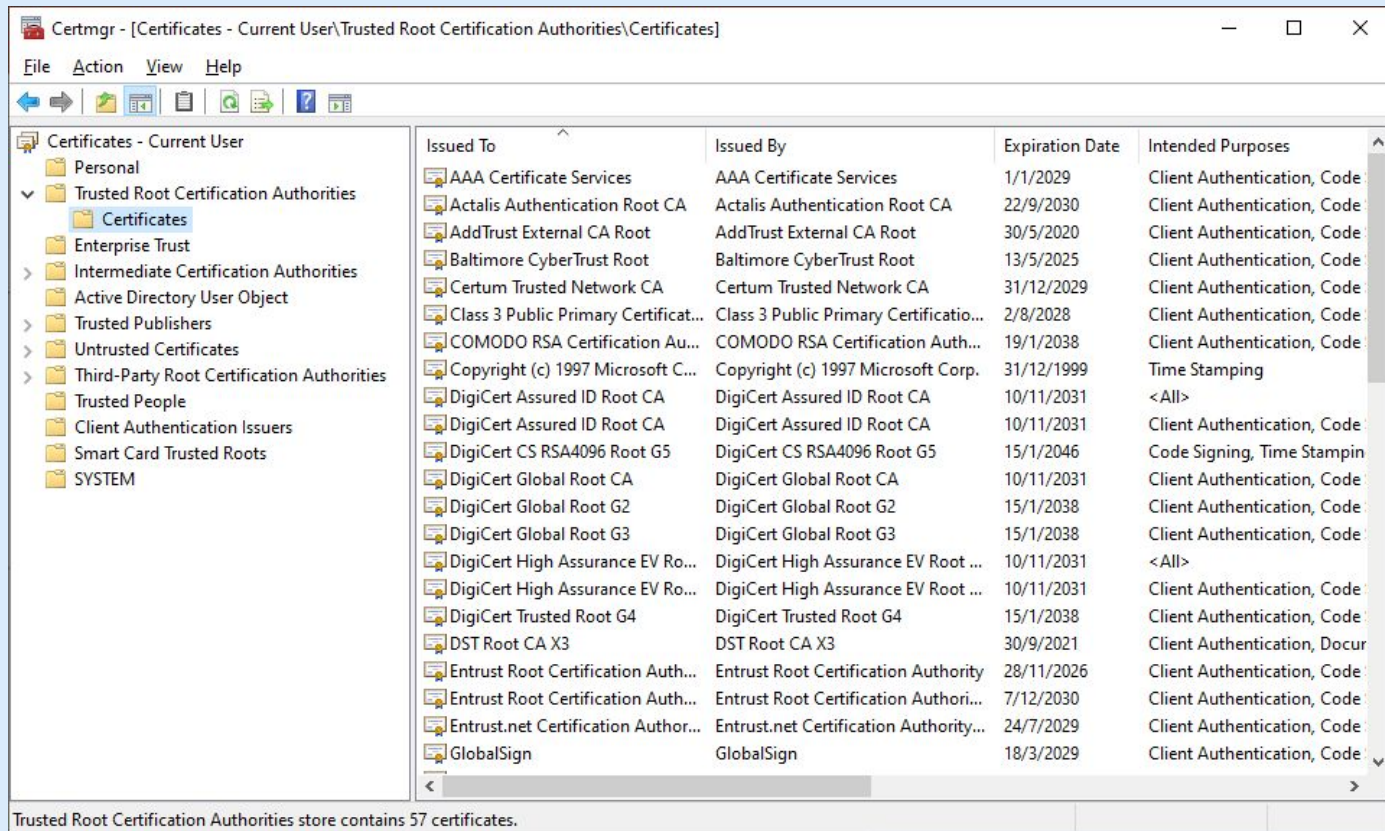


- All operating systems come with a pre-installed list of trusted CAs.
- There are several vendors
 - IdenTrust
 - DigiCert
 - Sectigo (Comodo)
 - Lets Encrypt: issues free certificates
- OpenSSL is a free and open source library. It can be used to setup your own CA server.

Trusted CAs – Check your PC



Windows: launch Certmgr.msc

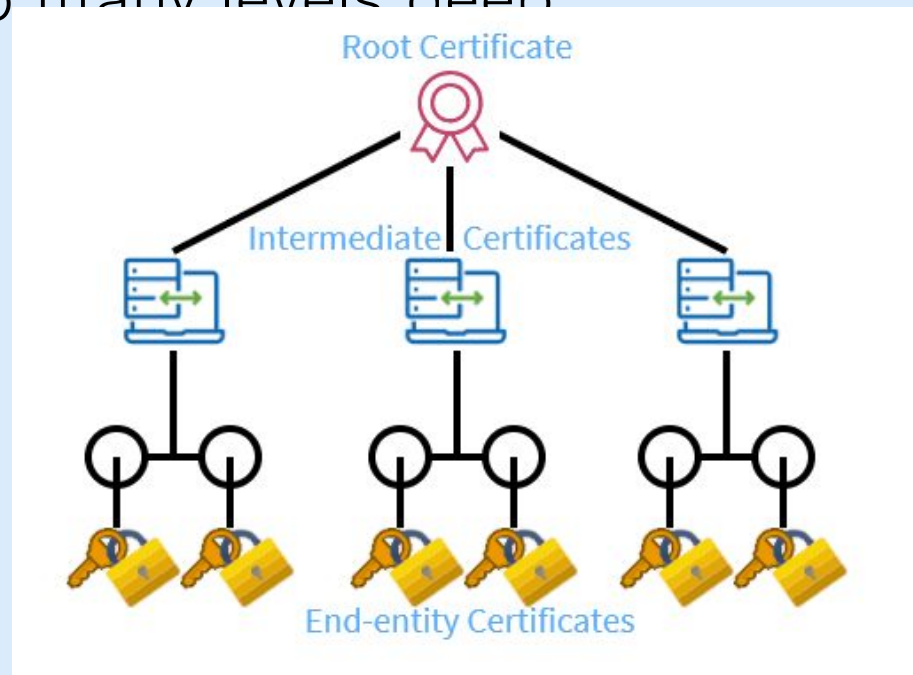


All trusted authorities are present in system's **certificates store** , aka **trust store** . This is a highly security-critical component of system . What would happen if attackers could manipulate the certificate store?

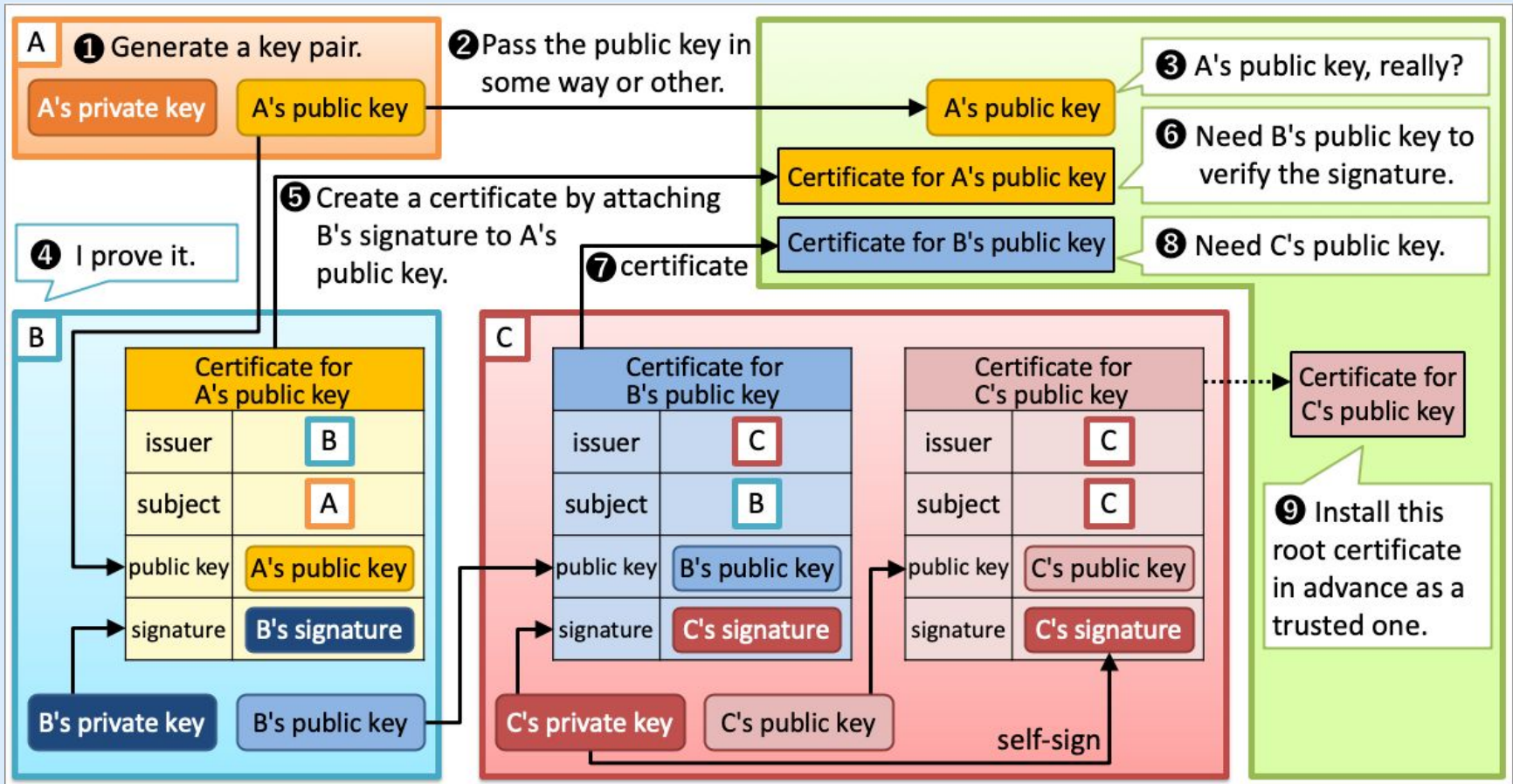
Chain of Trust



- Instead of getting a certificate directly from a root CA, it is more practical to get one from an intermediate CA which already has a certificate from root CA.
- This hierarchy can go many levels deep



Chain of Trust



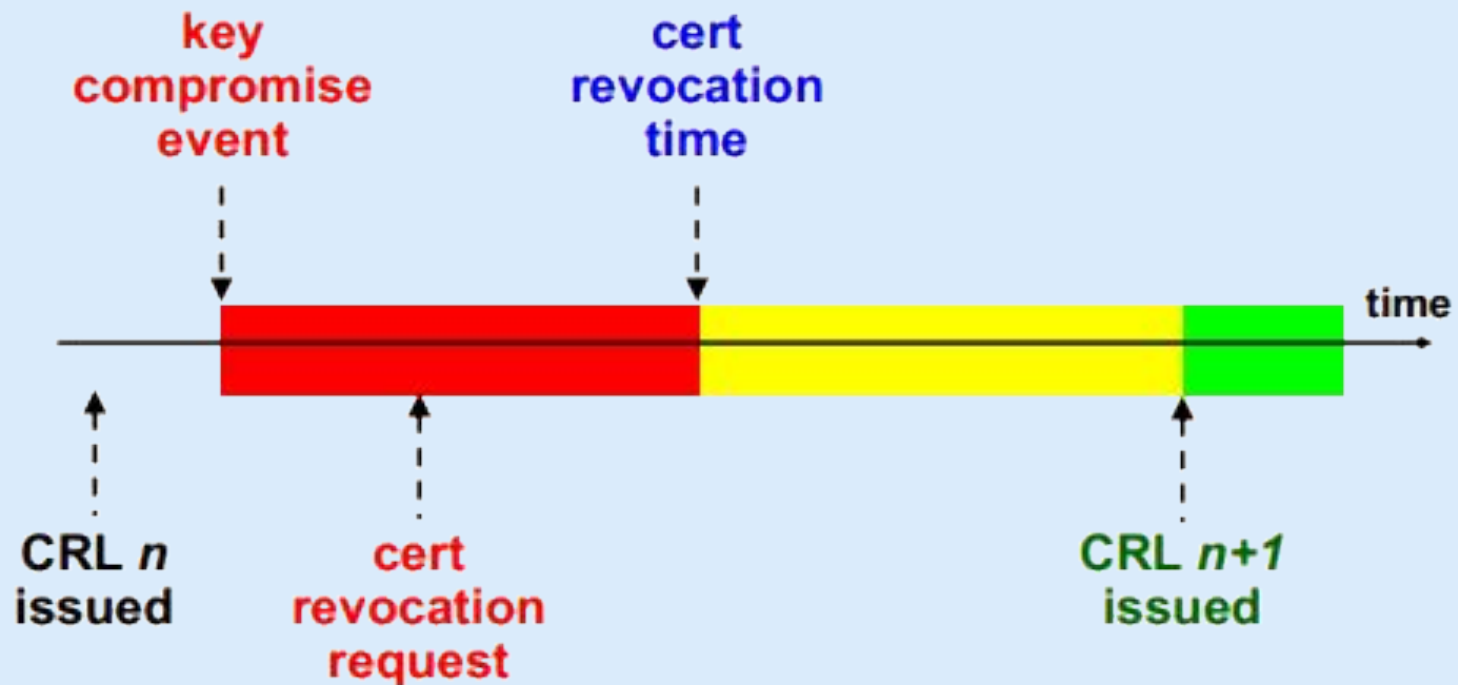
<https://darutk.medium.com/illustrated-x-509-certificate-84aece2c5c2e>

Certificate Revocation List (CRL)



- Certificates may need to be revoked (prior to expiration) for several reasons
- Subject may request revocation because
 - Subject's private key was compromised
 - HR reasons, e.g. employee left the company
 - Temporary revocation (on "hold") e.g. resource on leave
 - Subject changed names, physical address, DNS
- CA themselves may decide to revoke because
 - Subject provided false information
 - CA's private key was compromised!
- CAs maintain lists of revoked/cancelled certificates. These lists are published by CA frequently

Certificate Revocation Timeline



CRL Drawbacks



- Certificate revocation lists
 - Too much work on the client
 - Too much traffic on internet
 - Not used
- Alternate: Online Certificate Status Protocol
 - CA's always-online revocation server
 - Provides current information
 - Saves traffic on the internet



- Online certificate status protocol
- IETF–PKIX standard to verify online if a certificate is valid:
 - good/verified
 - revoked
 - revocation time
 - revocation reason
 - unknown
- response must be signed by the responder server (not by the CA!)
 - the OCSP server certificate cannot be verified with OCSP itself!

OCSP Usage



subject
server
e.g.
youtube.com



a. request certificate
for public key A



b. issue cert-A



CA server



end user



OCSP
responder



— . — . — . Ahead of time
— — — — — At communication

OCSP Usage



subject
server

e.g.
youtube.com



a. request certificate
for public key A



b. issue cert-A



CA server



1. request
certified
public key

2. here is
cert-A



end user



OCSP
responder

--- Ahead of time
— At communication

OCSP Usage



subject
server

e.g.
youtube.com



a. request certificate
for public key A



b. issue cert-A



CA server



1. request
certified
public key

2. here is
cert-A



end user



3. ✓ not expired
and signed by a
trusted CA

OCSP
responder



--- Ahead of time
— At communication time

OCSP Usage



subject
server

e.g.
youtube.com



a. request certificate
for public key A



b. issue cert-A



CA server



1. request
certified
public key

2. here is
cert-A



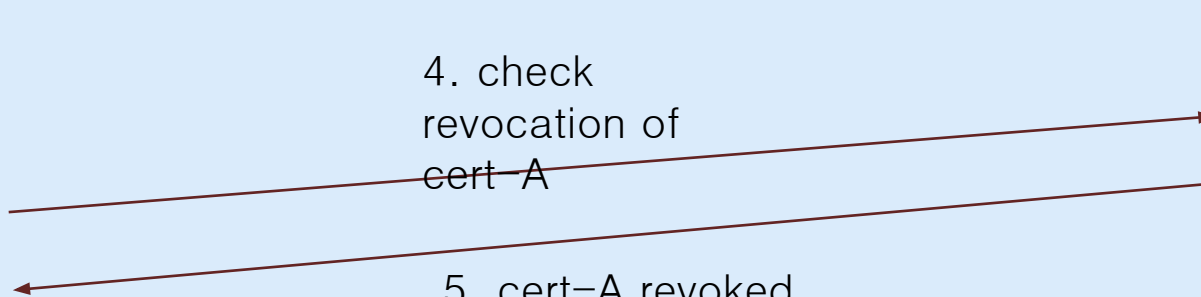
end user



4. check
revocation of
cert A

5. cert-A revoked
two days ago

3. ✓ not expired
and signed by a
trusted CA



OCSP
responder

--- Ahead of time
— At communication

OCSP Usage

